

Panduan Integrasi CMS ↔ Timedoor FAQ Bot (Cobee) API

Dokumen ini adalah **kontrak API** yang perlu disiapkan tim CMS (tim lain) agar chatbot **Cobee** bisa dipasang di CMS dengan aman dan setiap percakapan tercatat identitasnya (bukan "Anonim").

Base URL (produksi): <https://timedoorchatbot-production.up.railway.app>

Versi dokumen: disesuaikan dengan kode backend terbaru ([main.py](#) , [auth.py](#) , [config.py](#) , [api_keys.py](#)). Lihat §14 [Perubahan penting](#) untuk beda dari draf lama.

0. Ringkasan Cepat (TL;DR)

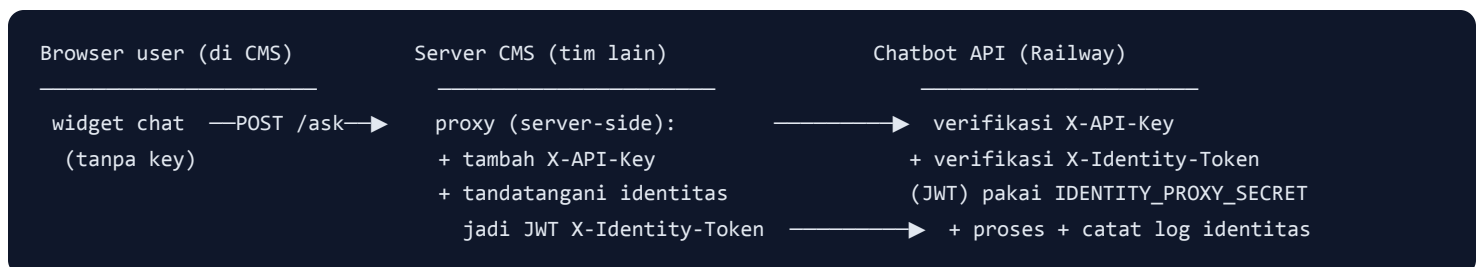
Untuk tim CMS ada **3 hal wajib**:

1. **Buat endpoint proxy di server CMS** (mis. [proxy.php](#)). Browser **TIDAK boleh** memanggil API chatbot langsung, karena ada 2 rahasia yang harus tetap di server:
 - [COBEE_API_KEY](#) → dikirim sebagai header [X-API-Key](#) .
 - [IDENTITY_PROXY_SECRET](#) → dipakai untuk **menandatangani** identitas user.
2. **Kirim identitas user** pada setiap request [/ask](#) & [/ask/stream](#) , dalam bentuk **token bertanda tangan** [X-Identity-Token](#) (JWT HS256). Wajib berisi [sub](#) (ID user unik & stabil), [name](#) , [email](#) .
3. **Wajib login**. Percakapan tanpa identitas valid **ditolak 401** (mode anonim dinonaktifkan — semua chat harus tercatat).

Dua rahasia ([COBEE_API_KEY](#) dan [IDENTITY_PROXY_SECRET](#)) diberikan **terpisah** oleh tim chatbot dan nilainya harus **sama persis** dengan yang ada di server chatbot.

⚠ **Jalur lama sudah dihapus.** Header [X-User-Id](#) / [X-User-Name](#) / [X-User-Email](#) + [X-Proxy-Secret](#) , serta identitas lewat **body** ([user_id](#) / [user_name](#) / [user_email](#)) dan mode **"embed"**, **tidak lagi diterima** backend. Satu-satunya cara mengirim identitas dari CMS adalah [X-Identity-Token](#) (JWT).

1. Arsitektur: kenapa harus pakai proxy?



Prinsip: rahasia ([X-API-Key](#)) dan secret tanda tangan hanya hidup di **server CMS**. Browser hanya bicara ke server CMS sendiri, jadi user tidak pernah bisa melihat/mencuri kredensial dari tab Network, dan identitas tidak bisa dipalsukan dari browser.

2. Checklist yang harus disiapkan tim CMS

- [] Endpoint **proxy server-side** yang meneruskan request ke Base URL di atas.
- [] Simpan 2 secret di server CMS: `COBEE_API_KEY` , `IDENTITY_PROXY_SECRET` .
- [] Ambil identitas user dari **session login CMS** (bukan dari input browser).
- [] Pada tiap request `/ask` & `/ask/stream` , buat + tanda tangani **JWT** berisi `sub` , `name` , `email` , lalu kirim sebagai header `X-Identity-Token` .
- [] Kirim juga `X-API-Key` (dari `COBEE_API_KEY`).
- [] Teruskan body JSON dari widget apa adanya (lihat §6).
- [] Pastikan **jam server sinkron (NTP)** — token berumur pendek ($\pm$ 120 detik).
- [] Hanya izinkan path yang diperlukan (**allowlist**): `/ask` , `/ask/stream` , `/taxonomy` , `/stats/popular` , `/feedback` .
- [] Tangani **HTTP 401** (user belum login) di sisi UI (mis. minta login dulu).
- [] Untuk `/ask/stream` (SSE), proxy **tidak boleh mem-buffer** — teruskan streaming.

3. Data identitas (primary) yang WAJIB dikirim

Inilah jawaban langsung untuk pertanyaan soal "primary data":

Field	Wajib	Ini "primary key"?	Keterangan
<code>sub</code>	✓ Ya	Ya — kunci utama	ID user CMS yang unik & stabil sepanjang waktu. Dipakai untuk mengenali "ini user yang sama" antar hari/percakapan. Jangan pakai nilai yang bisa berubah.
<code>name</code>	✓ Ya	Tidak	Nama tampilan untuk label di riwayat admin.
<code>email</code>	✓ Ya	Tidak	Email user; label tambahan + fallback identitas.

Penting soal `sub` :

- `sub` = **primary key user** di sisi chatbot. Gunakan **ID internal CMS** (mis. `users.id = 12345`), karena paling stabil.
- Kalau CMS memakai email sebagai ID dan email bisa diganti user, lebih aman tetap kirim ID internal sebagai `sub` , dan email hanya di field `email` .
- Nilai `sub` yang sama = dianggap **user yang sama**, walau beda hari/sesi.

Mode **anonim dihapus**. Kalau `sub` / `name` / `email` kosong semua (atau token tidak valid), request `/ask` ditolak **401** . Jadi user harus login di CMS sebelum bisa chat.

3.1 Arti `sub` , siapa yang membuat, & identitas lintas waktu

`sub` = "subject" pada standar JWT = "token ini tentang siapa". Di sini `sub` berarti **ID user di database CMS** (primary key tabel user CMS). Nilai ini tetap seumur hidup akun.

"id"	Milik siapa	Dipakai untuk	Ini <code>sub</code> ?
ID user CMS (PK tabel user CMS)	Database CMS	Identitas user lintas waktu di chatbot	✓ Ya
Username akun chatbot (email)	Tabel akun chatbot	Login langsung ke dashboard/chatbot	✗
<code>session_id</code> (<code>sess-YYYY-MM-DD-<uuid></code>)	Dibuat di browser	Mengelompokkan satu percakapan	✗
<code>messageId</code>	Frontend	Umpan balik per-pesan (up/down)	✗
String token JWT	Dibuat proxy	Kredensial sesaat (bukan id)	✗

Siapa yang membuat `sub` ? CMS, bukan chatbot. Chatbot tidak membuat id untuk user CMS; ia hanya menyimpan nilai `sub` apa adanya sebagai label log (kolom `user_id`).

Identitas lintas waktu: yang menyambungkan "ini user yang sama besok" **hanya `sub`** — bukan token (selalu baru) dan bukan `session_id` (ganti tiap percakapan).

Syarat aman: jangan pakai email sebagai `sub` ; pakai id numerik/opaque internal CMS; jangan daur ulang id bekas user yang dihapus.

4. Autentikasi

Ada **dua lapis** yang dikirim proxy pada tiap request `/ask` & `/ask/stream` :

4.1 API key aplikasi — header `X-API-Key`

- Nilainya dari env `COBEE_API_KEY` (diberikan tim chatbot; format `tdk_...`).
- Membuktikan pemanggil adalah **aplikasi CMS resmi**.
- **Hanya dari server** (jangan pernah taruh di HTML/JS browser).
- Wajib bila backend mengaktifkan proteksi (`PUBLIC_API_REQUIRED=true`). Kalau salah/tidak dikirim → `401` .

4.2 Identitas user — header `X-Identity-Token` (JWT HS256)

Token bertanda tangan yang membuktikan **siapa user-nya**, tanpa mengirim secret mentah.

- **Algoritma:** `HS256` (HMAC-SHA256).
- **Secret tanda tangan:** `IDENTITY_PROXY_SECRET` (sama persis dengan server chatbot).
- **Struktur:** `base64url(header) . base64url(payload) . base64url(signature)` .

Header:

```
{ "alg": "HS256", "typ": "JWT" }
```

Payload (klaim):

```
{
  "sub": "12345",           // WAJIB: ID user unik & stabil (primary key)
  "name": "Budi Santoso",   // WAJIB: nama tampilan
  "email": "budi@contoh.com", // WAJIB: email user
  "iat": 1788492711,        // issued-at (epoch detik)
  "exp": 1788492831         // expiry = iat + 120 detik (WAJIB & pendek)
}
```

Signature:

```
signature = HMAC_SHA256( base64url(header) + "." + base64url(payload), IDENTITY_PROXY_SECRET )
```

Aturan penting:

- **exp wajib** dan sebaiknya pendek (± 120 detik). Buat token **baru tiap request**. Token tanpa **exp** (atau **exp** lewat) $\rightarrow$ ditolak.
- Karena **exp** pendek, **jam server CMS harus sinkron (NTP)**.
- Secret **tidak pernah dikirim** — yang dikirim hanya hasil tanda tangannya.
- Base64 yang dipakai adalah **base64url tanpa padding** (**+** $\rightarrow$ **-** , **/** $\rightarrow$ **_** , buang **=**).

Backend memverifikasi tanda tangan dengan **IDENTITY_PROXY_SECRET** dan bersifat **fail-closed**: kalau secret belum diset di server, atau tanda tangan tidak cocok, atau token kedaluwarsa $\rightarrow$ identitas ditolak (**401** di **/ask**).

5. Referensi Endpoint

Semua endpoint di bawah bersifat publik untuk end-user (tidak butuh token admin). **Hanya `/ask` & `/ask/stream`** yang wajib membawa **X-API-Key** + **X-Identity-Token**. Endpoint **`/taxonomy`**, **`/stats/popular`**, **`/feedback`** boleh diteruskan tanpa identitas, tapi tetap lewat proxy.

5.1 **POST `/ask`** — tanya jawab (non-streaming)

Request body (JSON):

```
{
  "question": "Bagaimana cara reset password?", // WAJIB, tidak boleh kosong
  "domain": null,                               // opsional: batasi ke satu domain, mis. "HR". null = semua
  "topic": null,                                // opsional: batasi ke satu label topik. null = semua
  "history": [                                  // opsional: beberapa giliran terakhir (multi-turn)
    { "role": "user", "text": "Halo" },
    { "role": "assistant", "text": "Halo, ada yang bisa dibantu?" }
  ],
  "session_id": "sess-2026-09-09-a1b2c3d4"      // opsional tapi disarankan, lihat §7
}
```

Field **user_id** / **user_name** / **user_email** di body **tidak dipakai untuk auth** (sisalama) dan diabaikan server. Identitas yang dipercaya HANYA dari **X-Identity-Token**.

Response 200 (JSON):

```
{
  "answer": "Untuk reset password, buka menu ...",
  "citations": [
    { "source": "Panduan Akun.pdf", "snippet": "...", "page": 18 }
  ],
  "related_docs": [
    { "source": "FAQ Login.pdf", "domain": "Akun" }
  ]
}
```

5.2 POST /ask/stream — tanya jawab (streaming / SSE)

Body sama dengan `/ask`. Respons berupa **Server-Sent Events** (`Content-Type: text/event-stream`). Tiap baris berbentuk `data: {json}` dengan field `type` :

type	Arti
text	Potongan jawaban; <code>value</code> (string) ditambahkan ke layar.
citations	Daftar sitasi (dikirim sekali, biasanya di akhir).
error	Gagal; <code>value</code> sudah berupa pesan ramah user.
done	Stream selesai sukses.

Contoh potongan stream:

```
data: {"type":"text","value":"Untuk reset "}
data: {"type":"text","value":"password..."}
data: {"type":"citations","value":[{"source":"Panduan Akun.pdf","page":18}]}
data: {"type":"done"}
```

Pada mode stream, error **tidak** dikirim sebagai HTTP status (status sudah terkunci saat byte pertama terkirim), melainkan sebagai event `{"type":"error"}` . Namun cek identitas (`401`) tetap terjadi **sebelum** stream dimulai, jadi user belum login tetap dapat `401` biasa.

5.3 GET /taxonomy — daftar kategori/domain/topik (untuk dropdown)

```
{
  "categories": ["..."],
  "domains": ["HR", "Akun", "..."],
  "topics": ["Cuti", "Login", "..."],
  "topics_by_domain": { "HR": ["Cuti", "Lembur"], "Akun": ["Login"] }
}
```

5.4 GET /stats/popular?limit=6 — pertanyaan sering ditanyakan

```
[
  { "question": "Bagaimana cara reset password?", "count": 42 },
  { "question": "Berapa hari cuti tahunan?", "count": 30 }
]
```

`limit` opsional (default `6`). Cocok untuk empty-state / "chip" saran pertanyaan.

5.5 POST /feedback — umpan balik jawaban (up/down)

```
{
  "messageId": "abc-123",    // ID pesan di sisi frontend
  "value": "up",             // "up" atau "down"
  "question": "...",         // opsional
  "answer": "...",          // opsional
}
```

Response: `{ "status": "ok", "value": "up" }`

5.6 GET /health — cek status

```
{ "status": "ok", "model": "gemini-flash-latest", "store_configured": true }
```

6. Body request & `session_id`

- `question` **wajib** (tidak boleh kosong → `422`).
- `domain` / `topic` opsional; `null` = cari di semua.
- `history` opsional (multi-turn); backend memakai ≤ 12 giliran terakhir.
- `session_id` opaque untuk **mengelompokkan** pesan dalam satu percakapan.

`session_id` — pengelompokan percakapan

- **Siapa yang membuat:** dibuat di sisi klien (widget), lalu dikirim di body.
- **Format widget saat ini:** `sess-YYYY-MM-DD-<uuid>`.
- **Aturan pakai:** nilai sama untuk semua pesan dalam satu percakapan; ganti hanya saat user memulai percakapan baru.
- `session_id` **bukan** identitas/auth — hanya pengelompokan log. Identitas tetap dari `X-Identity-Token`.

7. Kebijakan wajib-login (mode anonim dinonaktifkan)

Setiap `POST /ask` dan `POST /ask/stream` **wajib** membawa identitas valid. Kalau tidak ada identitas (token tidak dikirim / tidak valid / kedaluwarsa), backend mengembalikan:

HTTP 401

```
{ "detail": "Identitas wajib: percakapan anonim tidak diizinkan. Login akun atau akses lewat CMS terautentikasi (proxy)" }
```

Implikasi untuk CMS: pengunjung yang belum login tidak bisa chat. Sarankan: sembunyikan/kunci widget sampai user login, atau tampilkan ajakan login saat menerima `401`.

8. Pasang widget di halaman CMS

Tempel snippet ini di layout/halaman CMS tempat chat ingin muncul:

```
<div id="td-chatbot"></div>
<script src="https://timedoor-chat-bot-two.vercel.app/widget.js"
  data-td-chatbot
  data-api-url="https://cms.timedooracademy.com/cobee-proxy"
  data-title="Cobee"
  data-subtitle="Ask me anything!"></script>
```

PENTING:

- `data-api-url` **HARUS** menunjuk ke endpoint proxy milik CMS, BUKAN langsung ke Railway. Widget memanggil endpoint relatif: `/ask`, `/ask/stream`, `/taxonomy`, `/stats/popular`, `/feedback` — jadi proxy WAJIB meneruskan **semuanya**.
- **JANGAN** mengisi `data-api-key` atau `data-user-*` di snippet. Jalur identitas via browser sudah dihapus. API key & identitas HANYA disuntikkan di server (§9).

9. Contoh implementasi proxy

9.1 PHP (menandatangani JWT + meneruskan request + allowlist + SSE)

```
<?php
// ==== Rahasia (dari env server, JANGAN di browser) ====
$API_KEY      = getenv('COBEE_API_KEY');          // -> header X-API-Key
$PROXY_SECRET = getenv('IDENTITY_PROXY_SECRET');  // -> secret tanda tangan JWT
$BACKEND      = getenv('CHATBOT_API_BASE') ?: 'https://timedoorchatbot-production.up.railway.app';

// ==== Ambil identitas dari SESSION login CMS (bukan dari input browser) ====
session_start();
$u = $_SESSION['user'] ?? null; // sesuaikan dgn struktur session CMS

function b64url($raw) { return rtrim(strtr(base64_encode($raw), '+/', '-_'), '='); }
function sign_identity_token($secret, $sub, $name, $email) {
    $now = time();
    $header = b64url(json_encode(['alg' => 'HS256', 'typ' => 'JWT']));
    $payload = b64url(json_encode([
        'sub' => (string)$sub, 'name' => $name, 'email' => $email,
        'iat' => $now, 'exp' => $now + 120,
    ], JSON_UNESCAPED_UNICODE));
    $sig = b64url(hash_hmac('sha256', "$header.$payload", $secret, true));
    return "$header.$payload.$sig";
}

// ==== Allowlist endpoint + method ====
$ALLOWED = [
    '/ask'          => ['POST'],
    '/ask/stream'    => ['POST'],
    '/taxonomy'      => ['GET'],
    '/stats/popular' => ['GET'],
    '/feedback'      => ['POST'],
];
$method = $_SERVER['REQUEST_METHOD'];
$path    = parse_url($_SERVER['REQUEST_URI'], PHP_URL_PATH); // relatif thd data-api-url
$query   = $_SERVER['QUERY_STRING'] ?? '';
if ($method === 'OPTIONS') { http_response_code(204); exit; }
if (!isset($ALLOWED[$path])) { http_response_code(404); exit; }
if (!in_array($method, $ALLOWED[$path], true)) { http_response_code(405); exit; }
$isStream = ($path === '/ask/stream');
$needsIdentity = in_array($path, ['/ask', '/ask/stream'], true);

// Untuk endpoint chat, user WAJIB login.
if ($needsIdentity && !$u) {
    http_response_code(401);
    echo json_encode(['detail' => 'Silakan login dulu untuk memakai chat.']);
    exit;
}

$headers = ['X-API-Key: ' . $API_KEY];
if ($needsIdentity) {
    $token = sign_identity_token($PROXY_SECRET, $u['id'], $u['name'], $u['email']);
    $headers[] = 'X-Identity-Token: ' . $token;
```



```

}

$hasBody = in_array($method, ['POST', 'PUT', 'PATCH'], true);
$body = $hasBody ? file_get_contents('php://input') : null;
if ($hasBody) { $headers[] = 'Content-Type: application/json'; }

$ch = curl_init($BACKEND . $path . ($query !== '' ? ('?' . $query) : ''));
curl_setopt_array($ch, [
    CURLOPT_CUSTOMREQUEST => $method,
    CURLOPT_HTTPHEADER    => $headers,
]);
if ($hasBody) { curl_setopt($ch, CURLOPT_POSTFIELDS, $body); }

if ($isStream) {
    header('Content-Type: text/event-stream');
    header('Cache-Control: no-cache');
    header('X-Accel-Buffering: no'); // matikan buffering nginx
    while (ob_get_level() > 0) { ob_end_flush(); }
    curl_setopt($ch, CURLOPT_WRITEFUNCTION, function ($ch, $chunk) {
        echo $chunk; flush(); return strlen($chunk);
    });
    curl_exec($ch);
} else {
    curl_setopt($ch, CURLOPT_RETURNTRANSFER, true);
    $resp = curl_exec($ch);
    http_response_code(curl_getinfo($ch, CURLINFO_HTTP_CODE) ?: 502);
    header('Content-Type: application/json');
    echo $resp !== false ? $resp : json_encode(['error' => curl_error($ch)]);
}
curl_close($ch);

```

9.2 Node.js (Express) — bagian tanda tangan token + relay

```
import express from "express";
import crypto from "crypto";

const app = express();
const BASE = process.env.CHATBOT_API_BASE;
const API_KEY = process.env.COBBEE_API_KEY;
const PROXY_SECRET = process.env.IDENTITY_PROXY_SECRET;

const b64url = (buf) =>
  Buffer.from(buf).toString("base64").replace(/\+/g, "-").replace(/\//g, "_").replace(/>=+$/g, "");

function signIdentityToken({ sub, name, email }) {
  const now = Math.floor(Date.now() / 1000);
  const header = b64url(JSON.stringify({ alg: "HS256", typ: "JWT" }));
  const payload = b64url(JSON.stringify({ sub: String(sub), name, email, iat: now, exp: now + 120 }));
  const sig = b64url(crypto.createHmac("sha256", PROXY_SECRET).update(`${header}.${payload}`).digest());
  return `${header}.${payload}.${sig}`;
}

const ALLOWED = {
  "/ask": ["POST"], "/ask/stream": ["POST"],
  "/taxonomy": ["GET"], "/stats/popular": ["GET"], "/feedback": ["POST"],
};

const STRIP = new Set(["content-encoding", "content-length", "transfer-encoding", "connection"]);

app.use("/cobee-proxy", express.raw({ type: "*/*" })), async (req, res) => {
  const path = req.path.replace(/\/+$/, "") || "/";
  const methods = ALLOWED[path];
  if (req.method === "OPTIONS") return res.sendStatus(204);
  if (!methods) return res.sendStatus(404);
  if (!methods.includes(req.method)) return res.sendStatus(405);

  const needsIdentity = path === "/ask" || path === "/ask/stream";
  const user = req.session?.user; // dari session login CMS
  if (needsIdentity && !user) return res.status(401).json({ detail: "Silakan login dulu." });

  const headers = { "X-API-Key": API_KEY };
  if (needsIdentity) {
    headers["X-Identity-Token"] = signIdentityToken({ sub: user.id, name: user.name, email: user.email });
  }
  const hasBody = ["POST", "PUT", "PATCH"].includes(req.method);
  if (hasBody) headers["Content-Type"] = "application/json";
  const qs = req.originalUrl.includes("?") ? "?" + req.originalUrl.split("?")[1] : "";

  const upstream = await fetch(`${BASE}${path}${qs}`, {
    method: req.method, headers, body: hasBody ? req.body : undefined,
  });
  res.status(upstream.status);
  upstream.headers.forEach((v, k) => { if (!STRIP.has(k.toLowerCase())) res.setHeader(k, v); });
  const reader = upstream.body.getReader(); // pipe (SSE-safe)
  for (;;) { const { done, value } = await reader.read(); if (done) break; res.write(Buffer.from(value)); res.flush?.(); }
```

```
res.end();
});
```

10. Contoh uji cepat dengan curl

```
# Ganti <API_KEY> dan <IDENTITY_TOKEN> (token bisa dibuat oleh proxy).
curl -s https://timedoorchatbot-production.up.railway.app/ask \
  -H 'Content-Type: application/json' \
  -H 'X-API-Key: <API_KEY>' \
  -H 'X-Identity-Token: <IDENTITY_TOKEN>' \
  -d '{"question": "Bagaimana cara reset password?", "session_id": "sess-test-1"}'

# Tanpa identitas -> harus 401
curl -i https://timedoorchatbot-production.up.railway.app/ask \
  -H 'Content-Type: application/json' \
  -H 'X-API-Key: <API_KEY>' \
  -d '{"question": "halo"}'
```

11. Kode status & error

Status	Arti	Yang harus dilakukan CMS
200	Sukses	Tampilkan <code>answer</code> + <code>citations</code> .
401	Identitas wajib / token tidak valid / kedaluwarsa ATAU <code>X-API-Key</code> salah/kurang (saat proteksi aktif)	Minta user login; buat ulang token; cek jam server (NTP) & samakan <code>IDENTITY_PROXY_SECRET</code> / <code>COBEE_API_KEY</code> .
422	Body tidak valid (mis. <code>question</code> kosong)	Validasi input sebelum kirim.
429	Terlalu banyak request (rate limit)	Backoff / coba lagi nanti (lihat header <code>Retry-After</code>).
5xx	Error server	Coba lagi; laporkan bila menetap.

Catatan: `403` **tidak** dipakai di jalur chat CMS. `403` hanya muncul untuk akun login yang mencoba menembus endpoint khusus admin.

12. Keamanan — lakukan & hindari

Lakukan

- Simpan `COBEE_API_KEY` & `IDENTITY_PROXY_SECRET` sebagai **env server** saja.
- Ambil identitas dari **session login server**, bukan parameter dari browser.

- Buat token **baru tiap request** dengan `exp` pendek.
- Batasi path proxy dengan **allowlist**.
- Gunakan **HTTPS** di semua sisi.

Hindari

- ❌ Menaruh API key / secret di HTML, JS, atau atribut `data-*` widget.
- ❌ Membiarkan browser mengirim identitas mentah (bisa dipalsukan user).
- ❌ Memakai `exp` panjang atau token statis yang dipakai ulang lama.
- ❌ Mengekspos endpoint proxy tanpa allowlist (bisa jadi open proxy).

13. Ringkasan variabel lingkungan (server CMS)

Env	Dipakai untuk	Catatan
<code>CHATBOT_API_BASE</code>	Base URL chatbot	<code>https://timedoorchatbot-production.up.railway.app</code>
<code>COBEE_API_KEY</code>	Header <code>X-API-Key</code>	Key konsumen <code>cms-server</code> . Sama dgn server chatbot. Rahasiakan.
<code>IDENTITY_PROXY_SECRET</code>	Menandatangani JWT <code>X-Identity-Token</code>	Sama persis dgn server chatbot. Rahasiakan.
<code>WIDGET_JS</code>	URL script widget	<code>https://timedoor-chat-bot-two.vercel.app/widget.js</code>

Lampiran: ringkasan header tiap request chat

```
POST /ask (atau /ask/stream)
Content-Type: application/json
X-API-Key: <COBEE_API_KEY> # membuktikan aplikasi resmi
X-Identity-Token: <JWT HS256> # membuktikan siapa user-nya (sub/name/email)

Body: { "question": "...", "session_id": "...", "domain": null, "topic": null, "history": [] }
```

14. Perubahan penting dari versi sebelumnya

Dibanding draf panduan lama, kontrak sekarang disesuaikan dengan kode terbaru:

1. **Identitas hanya via `X-Identity-Token` (JWT)**. Header lama `X-User-Id/Name/Email` + `X-Proxy-Secret`, jalur body `user_*`, dan mode **"embed"** sudah **DIHAPUS** dari backend.
2. **Wajib login (tanpa anonim)**. `/ask` & `/ask/stream` menolak `401` bila tidak ada identitas valid. Draf lama sempat menyebut fallback "Anonim" — itu tidak berlaku lagi.
3. **Kode error `X-API-Key` = `401`** (saat proteksi aktif), bukan `403`. `403` hanya untuk endpoint admin.
4. Secret verifikasi identitas = `IDENTITY_PROXY_SECRET` (satu env), dipakai untuk menandatangani & memverifikasi JWT.

15. Verifikasi setelah integrasi (QA)

- [] Request dari user login → `200`, dan di dashboard admin **nama muncul** (bukan "Anonim"), badge channel = **CMS**.
 - [] Request tanpa identitas → `401`.
 - [] Token dengan `IDENTITY_PROXY_SECRET` salah → `401`.
 - [] Token kedaluwarsa (jam server meleset) → `401` → pastikan NTP aktif.
 - [] `X-API-Key` tidak ada / salah (saat proteksi aktif) → `401`.
 - [] Di tab Network browser: **tidak ada** `X-API-Key` / secret / `X-Identity-Token` (semua ditambahkan server-side).
 - [] `session_id` konsisten dalam satu percakapan; ganti saat mulai percakapan baru.
 - [] Streaming (`/ask/stream`) tampil bertahap dan diakhiri event `done`.
 - [] `Sering ditanyakan` & dropdown domain terisi (berarti `/taxonomy` & `/stats/popular` ikut diteruskan proxy).
-

Dokumen ini dibuat berdasarkan kode backend `main.py` / `schemas.py` / `auth.py` / `config.py` / `api_keys.py` yang berlaku saat ini. Jika kontrak berubah, perbarui versi dokumen ini.